Ciberseguridad Organizacional: Ataques, Conceptos y Técnicas

Curso Introducción a la Ciberseguridad

- Aguilar Carrizales Miguel Ángel | 182318
- Aznar Cuevas Luis Eduardo | 179880
- Beltrán Reyna David | 183636
- Gómez Arreguín Donaldo Demián | 179822
- Morales Hernández Roberto Emiliano | 182377
- Rosales Ramírez Josué Emiliano | 181760

Amenazas Cibernéticas

¿Qué son?

Un entorno de amenazas cibernéticas es la composicion desde software malicioso (malware), la manipulación psicológica (ingeniería social) y la explotación de vulnerabilidades en hardware/software

El peligro que representan

Las organizaciones dependen de la integridad de sus sistemas. Los cibercriminales buscan interrumpir operaciones, secuestrar información o minar criptomonedas incluso (Cryptojacking) paralizando la productividad y generando pérdidas millonarias.

Clasificación de Amenazas (Vectores de Ataque)

Malware

- **Gusanos vs. Virus:** Los virus necesitan que el usuario los ejecute; los gusanos se autorreplican solos en la red.
- **Troyanos:** Se camuflan como actualizaciones o software legítimo para abrir puertas traseras.
- **Ransomware:** Secuestra información y bases de datos pidiendo rescates en criptomonedas.

Ingeniería Social

- **Pretexting:** Creación de una historia falsa (ej. hacerse pasar por soporte técnico) para robar contraseñas.
- **Tailgating:** Acceso físico no autorizado a instalaciones siguiendo de cerca a un empleado legítimo.

Ataques de Red

- **DDoS):** Uso de ejércitos de equipos infectados (*Botnets/Zombies*) para saturar y tumbar servidores.
- **Man-in-the-Middle:** Interceptación de tráfico sin cifrar en redes Wi-Fi públicas o creadas por atacantes.

Riesgos e Impactos

Vulnerabilidades existentes

Hardware

- **Rowhammer:** Al acceder repetidamente (martillar) a una fila de memoria de la RAM desencadena interferencias eléctricas que eventualmente corrompen los datos almacenados
- **Meltdown:** Rompe el aislamiento entre las aplicaciones de usuario y el sistema operativo (kernel), permitiendo que un programa acceda a la memoria privilegiada.
- **Spectre:** Engaña a las aplicaciones para que accedan a ubicaciones arbitrarias de su memoria, rompiendo la barrera de seguridad entre distintas aplicaciones.

Software

- **Desbordamiento de búfer (Buffer overflow):** Si un bloque de software está diseñado para almacenar 8 o 64 bits, y un atacante le envía de golpe 70 u 80 bits, el sistema colapsa o se desborda, creando un hueco que permite ingresar a la red o al equipo.
- **Actualizaciones maliciosas (Firmware):** Los atacantes logran vulnerar el software haciendo que se descargaran actualizaciones aparentemente legales que contienen una especie de malware (ejemplo: M.E.Doc. - NotPetya).
- **Fallas lógicas del código:** Abuso de errores de programación como "entradas no válidas" y las "condiciones de carrera".

Riesgo Humano

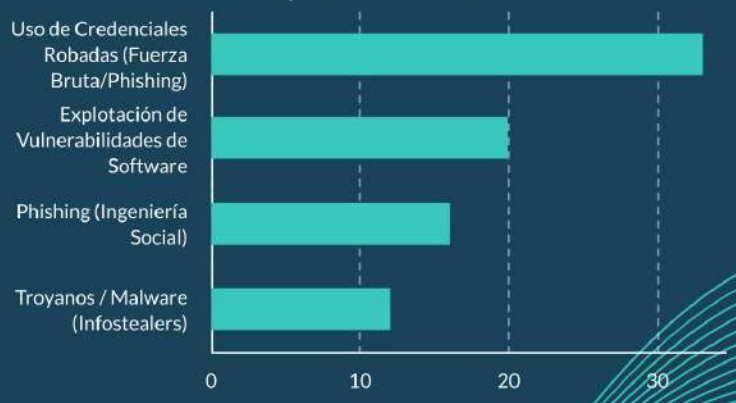
A pesar de los avances en firewalls y sistemas de detección, el usuario sigue siendo el principal vector de entrada. Esta gráfica ilustra cómo la mayoría de los incidentes de seguridad no ocurren por fallos técnicos complejos, sino que la manipulación del usuario sigue siendo la vulnerabilidad organizacional más grande.

El Eslabón Humano (DBIR 2025)

Impacto Empresarial

El panorama de amenazas ha evolucionado: los atacantes ya no suelen "forzar" la entrada con técnicas complejas, sino que prefieren explotar el eslabón más débil: la identidad y el software no parcheado, haciendo uso de métodos para iniciar una brecha de seguridad en entornos corporativos.

Principales Vectores de Acceso Inicial en Empresas (2025)



Estrategias de Mitigación

Autenticación Robusta
Crear contraseñas fuertes (mayúsculas, minúsculas, números y símbolos) para mitigar ataques de fuerza bruta y pulverización (spraying).

Cifrado de Comunicaciones
Toda conexión Wi-Fi debe tener contraseña (WPA2/WPA3) no solo para restringir el acceso, sino para encriptar las tramas de información y evitar que un *sniffer* robe los datos bancarios.

Seguridad Física Perimetral
Los *switches*, *routers* y servidores deben estar físicamente bloqueados. Un atacante interno puede conectarse directamente con un cable de red si no hay controles físicos.

Concientización y Actualización
Parchear sistemas constantemente (para evitar desbordamientos de búfer en memoria RAM o vulnerabilidades de CPU) y educar a los usuarios para no conectar USBs externos o abrir correos no verificados.

Referencias Bibliográficas.

Fuente Principal:

- Introducción a la Ciberseguridad, Módulo 2: Ataques, conceptos y técnicas. https://www.netacad.com/courses/introduction-to-cybersecurity?courseLang=en-US

Fuente de Datos Estadísticos y Gráficas:

- Verizon. (2025). *2025 Data Breach Investigations Report (DBIR).* https://www.verizon.com/business/resources/T16f/reports/2025-dbir-data-breach-investigations-report.pdf#:~:text=What%20you%20will%20find%20here.%20The%20Data,year%20from%20almost%20a%20hundred%20data%20contributors.